



Confidential



Vulnerability Disclosure Report

DemoCorp

January 12, 2026

In this report, we present discovered vulnerabilities disclosed by Defend Denmark's security professionals. Our findings aim to improve security and guide remediation efforts. By addressing these vulnerabilities promptly, we collectively contribute to a safer digital landscape.

IDOR In DownloadReceipt	
ReportID	DC-2026-12345
Suggested Severity	High
Suggested Reward	5000 - 10000 DKK
Impact	Breach of PII and financial information for DemoCorp's users.
Asset	https://my.democorp.is/api/myreceipts/DownloadReceipt.pdf
CVSS3.1	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

1 Executive Summary

This report details an Insecure Direct Object Reference (IDOR) vulnerability discovered in the DownloadReceipt.pdf endpoint on the my.democorp.is platform. The vulnerability allows an authenticated user to download other users' receipts by manipulating the receipt_id parameter. This flaw exposes Personally Identifiable Information (PII) such as names, email addresses, and phone numbers, posing a severe risk of data exposure and unauthorized access.

2 Technical Details

Insecure Direct Object Reference (IDOR) is a type of access control vulnerability that arises when an application directly references internal objects, such as files or database records, using user-supplied input without performing adequate authorization checks. This weakness allows attackers to manipulate identifiers, such as user IDs or document numbers, to access resources they are not supposed to, potentially exposing or modifying sensitive information.

In this case, the identified vulnerability is an IDOR affecting the DownloadReceipt.pdf endpoint. The issue is specifically caused by insufficient authorization checks on the receipt_id parameter, which permits any authenticated user to view arbitrary documents simply by altering this value in the request, leading to unauthorized access.

2.1 Vulnerability Description

The /api/myreceipts/DownloadReceipt.pdf endpoint accepts a receipt_id parameter to specify which receipt PDF to download. The application does not enforce object-level authorization to confirm that the authenticated user is permitted to access the requested receipt_id.

As a result, any authenticated user can modify receipt_id to another valid (including incremental) value and download receipts belonging to other users. This enables unauthorized access to sensitive receipt content, including PII and financial information.

2.2 Affected Component

- **Primary Asset:** <https://my.democorp.is/api/myreceipts/DownloadReceipt.pdf>
- **Entry Point:** GET <https://my.democorp.is/api/myreceipts/DownloadReceipt.pdf>
- **Vulnerable Parameter:** receipt_id
- **Attack Vector:** An authenticated attacker changes the receipt_id value in the GET request to a different valid or incremental identifier to retrieve another user's receipt PDF without authorization.

2.3 Proof of Concept

Vulnerable request example:

```
GET /api/myreceipts/DownloadReceipt.pdf?receipt_id=204412 HTTP/2
Host: my.democorp.is
Cookie: [...]
```

Unauthorized access by modifying the identifier:

```
https://my.democorp.is/api/myreceipts/DownloadReceipt.pdf?receipt_id=204413
```

Observed behavior: The server returns the receipt PDF for the modified receipt_id even when it belongs to a different user account.

2.3.1 Steps to Reproduce

1. Log into the my.democorp.is platform.
2. Navigate to the “Kvitteringer” tab.
3. Capture the request made when a receipt PDF is downloaded.
4. Modify the receipt_id parameter to any other valid or incremental value.
5. Send the request and observe that a receipt associated with another user is downloaded.

2.4 Impact Assessment

The vulnerability enables horizontal privilege escalation across user accounts by allowing authenticated users to access receipts they do not own. Receipts may contain PII (e.g., names, email addresses, phone numbers) and financial information. The scope is changed (S:C) because the attacker can access data belonging to other users outside their authorization boundary.

Root cause: Missing object-level authorization checks for receipt_id. The application relies solely on the provided receipt_id to select and return the document without verifying ownership or access rights.

2.5 Recommendation

1. Implement proper authorization: Enforce server-side object-level access control to verify that the requesting user is authorized to access the specified receipt_id before returning the PDF.
2. Use non-predictable identifiers: Replace sequential receipt IDs with UUIDs (or similarly non-enumerable identifiers) to make enumeration attacks more difficult.

3. Add monitoring and rate limiting: Detect and throttle repeated access attempts across multiple receipt_id values to reduce enumeration feasibility.

2.6 References

https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html

3 Appendix

INTERNAL PAY NOW

Reference Number	AT[REDACTED]CZ7
Transfer to	[REDACTED]
Account Type	Internal
Account Number	[REDACTED]0028
Account Name	[REDACTED]
Transfer From	[REDACTED]0027
Amount	GBP 10.00
Transfer When	02 Jan 2014
Purpose	Transaction is a general cash management instruction.
Note	

This is computer generated receipt no signature required.
Electronic Receipt owns no official legal effect, You may go to branch to get the paper receipt.

Figure 1: Screenshot evidence. Unauthorized receipt retrieval for someone else's account
(This screenshot is for demo purposes only)

No additional appendix content.